Ethical Hacking - ITA1432 - MCQ - Slot D

Total points 47/50

The respondent's email (**192472301.simats@saveetha.com**) was recorded on submission of this form.

0 of 0 points

Name of the Student

M.Supraja

Registration Number

192472301

MCQ

47 of 50 points

CO1-AT1

✓ Following an engagement against a multi-national bank's mobile app, management strictly asks A corporate security consultant to delete any mention of the CEO's compromised email account in the final official report. Recommend the most ethical response. *1/1

- Alter the report as requested, but leave a hidden cryptographic signature indicating tampering.
- Refuse the request entirely to maintain the integrity, accuracy, and objectivity of the audit. ✓
- Agree to the modification, but charge a premium fee for altering official compliance documents.
- Comply with the request, as the client owns the report and retains final editorial rights.

✓ An internal compliance auditor is offered a contract to audit a regional hospital's network, but they recently has a lucrative side-deal with their top competitor to leak data. Judge the decision to accept this auditing contract. *1/1

- Ethical, as their insider knowledge will result in a more thorough security test.
- Legal and ethical, provided they sign a supplementary non-disclosure agreement.
- Acceptable, as long as they only utilize automated scanning tools to remove bias.
- Unethical due to a severe conflict of interest that compromises the auditor's objectivity. ✓

✓ A tester is given authorization that expires at 6:00 PM. At 6:15 PM, testing is incomplete. What should the tester do? *1/1

- ○ Continue until testing is finished
- ◉ Stop testing and obtain renewed authorization before continuing ✓
- ○ Continue without recording the activity
- ○ Change the system time

✗ During a monitoring phase, A freelance vulnerability assessor detects an active, malicious attack originating against a university's research database. They immediately respond by launching a DDoS attack against the attacker's IP. Judge this defensive response. *0/1

- ○ It is legally protected under international self-defense doctrines for digital property.
- ○ It is acceptable if local law enforcement is notified within 24 hours of the counter-attack.
- ◉ It is illegal vigilantism (hacking back); ethical hacking does not authorize offensive actions against third parties. ✗
- ○ It is ethically mandated to prevent further harm to the client's network infrastructure.

Correct answer

- ◉ It is ethically mandated to prevent further harm to the client's network infrastructure.

✓ A corporate security consultant identifies a vulnerability in an online retail platform without any prior permission and creates a video showing the hack but hides the company name. Classify the hacker profile and evaluate the action. *1/1

- Hacktivism; aimed at political reform by exposing the company's weak security posture.
- Black hat behavior; driven strictly by malicious intent and violation of the CIA triad.
- Gray hat behavior; well-intentioned but legally perilous due to the strict lack of authorization. ✓
- White hat behavior; entirely ethical and legal since the ultimate goal was system defense.

✓ A network security auditor is offered a contract to audit a logistics and shipping API, but they recently is secretly building a competing software product. Judge the decision to accept this auditing contract. *1/1

- Unethical due to a severe conflict of interest that compromises the auditor's objectivity. ✓
- Ethical, as their insider knowledge will result in a more thorough security test.
- Legal and ethical, provided they sign a supplementary non-disclosure agreement.
- Acceptable, as long as they only utilize automated scanning tools to remove bias.

✓ During a monitoring phase, An independent ethical hacker detects an active, malicious attack originating against a federal tax web portal. They immediately respond by wiping the attacker's database of stolen credentials. Judge this defensive response. *1/1

- [x] It is illegal vigilantism (hacking back); ethical hacking does not authorize offensive actions against third parties. ✓
- [ ] It is legally protected under international self-defense doctrines for digital property.
- [ ] It is acceptable if local law enforcement is notified within 24 hours of the counter-attack.
- [ ] It is ethically mandated to prevent further harm to the client's network infrastructure

✓ An internal compliance auditor identifies a vulnerability in a regional hospital's network without any prior permission and fixes the flaw but leaves a harmless backdoor for themselves. Classify the hacker profile and evaluate the action. *1/1

- [ ] White hat behavior; entirely ethical and legal since the ultimate goal was system defense.
- [ ] Hacktivism; aimed at political reform by exposing the company's weak security posture.
- [x] Gray hat behavior; well-intentioned but legally perilous due to the strict lack of authorization. ✓
- [ ] Black hat behavior; driven strictly by malicious intent and violation of the CIA triad.

✓ A bug bounty participant is offered a contract to audit a social media startup, but they recently is currently suing the company for wrongful termination. Judge the decision to accept this auditing contract. *1/1

- (●) Unethical due to a severe conflict of interest that compromises the auditor's objectivity. ✓
- ( ) Acceptable, as long as they only utilize automated scanning tools to remove bias.
- ( ) Ethical, as their insider knowledge will result in a more thorough security test.
- ( ) Legal and ethical, provided they sign a supplementary non-disclosure agreement.

✗ Months after successfully finishing a penetration test on a university's research database, A bug bounty participant decides to retain the medical records accessed during the test on a local home server 'just in case'. Critique this post-engagement practice. *0/1

- ( ) It is legally required to prove the vulnerabilities existed in case of a future audit dispute.
- ( ) It is ethically acceptable as long as the home server is disconnected from the public internet.
- ( ) It is a standard industry practice to retain client data for long-term historical benchmarking.
- (●) It blatantly violates the ethical mandate for secure data destruction and strict confidentiality. ✗

Correct answer

- (●) It is ethically acceptable as long as the home server is disconnected from the public internet.

✓ A penetration tester is authorized to test IP addresses 192.168.1.10–192.168.1.20. Which target can the tester ethically assess? *1/1

- 192.168.1.5
- 192.168.1.25
- 192.168.1.15 ✓
- 192.168.2.10

✓ While officially authorized to test a logistics and shipping API, A senior security researcher assumes the contract implicitly includes a third-party managed database physically located in the office and proceeds to attack it. Judge the legal validity of this assumption. *1/1

- It is a valid assumption if both systems share the same internal IP subnet.
- Ethically and legally dangerous; authorization must always be explicit, documented, and unambiguous. ✓
- It is standard practice to ensure no blind spots remain in the client's overall audit.
- It is legally permissible as long as the actor is a certified and licensed professional.

✓ During testing, an ethical hacker finds evidence of an unexpected serious security issue. What should the hacker do? *1/1

- Ignore it because it was unexpected
- Follow the agreed escalation and reporting procedure ✓
- Delete the evidence
- Publish the evidence immediately

✓ A security tester discovers that the approved scope document contains unclear instructions about testing a particular server. What should the tester do? *1/1

- ○ Assume permission is granted
- ◉ Obtain clarification before testing that server ✓
- ○ Attack the server anonymously
- ○ Test first and ask later

✓ An organization hires a penetration tester to evaluate its network. Which document should be applied to determine permitted and prohibited activities? *1/1

- ◉ Rules of engagement ✓
- ○ Employee attendance record
- ○ Software installation guide
- ○ Marketing report

✓ While officially authorized to test a decentralized cryptocurrency exchange, An internal compliance auditor assumes the contract implicitly includes the building's physical security camera system and proceeds to attack it. Judge the legal validity of this assumption. *1/1

- [x] Ethically and legally dangerous; authorization must always be explicit, documented, and unambiguous. ✓
- [ ] It is legally permissible as long as the actor is a certified and licensed professional.
- [ ] It is standard practice to ensure no blind spots remain in the client's overall audit.
- [ ] It is a valid assumption if both systems share the same internal IP subnet.

✓ A company asks an ethical hacker to assess its website without affecting normal users. Which approach should the hacker apply? *1/1

- [x] Perform only approved, controlled, non-destructive testing ✓
- [ ] Shut down the website
- [ ] Delete vulnerable files
- [ ] Modify customer accounts

✓ A tester accidentally gains access to sensitive payroll records during an assessment. What should the tester do? *1/1

- [ ] Modify the records to demonstrate access
- [ ] Download all records
- [x] Minimize further access and report the finding ✓
- [ ] Share screenshots publicly

✓ A tester realizes that a scanning tool is sending requests to systems outside the approved IP range. What should the tester do? *1/1

- ○ Allow the scan to continue
- ◉ Stop or reconfigure the scan to remain within scope ✓
- ○ Increase the scanning speed
- ○ Ignore the issue

✓ A company asks a security professional to prepare a report after testing. Which information should be included to support ethical disclosure? *1/1

- ◉ Vulnerabilities, evidence, risk, and recommended remediation ✓
- ○ Personal opinions about employees
- ○ Unrelated customer information
- ○ Passwords for public distribution

✓ A penetration tester discovers login credentials while performing an authorized assessment. How should the credentials be handled? *1/1

- ○ Store them publicly
- ○ Use them on unrelated systems
- ◉ Protect them and use them only as permitted by the assessment scope ✓
- ○ Share them with friends

✓ During a monitoring phase, A corporate security consultant detects an active, malicious attack originating against an online retail platform. They immediately respond by deploying a reverse-shell to delete the attacker's tools. Judge this defensive response. *1/1

- It is legally protected under international self-defense doctrines for digital property.
- It is ethically mandated to prevent further harm to the client's network infrastructure.
- It is acceptable if local law enforcement is notified within 24 hours of the counter-attack.
- ◉ It is illegal vigilantism (hacking back); ethical hacking does not authorize offensive actions against third parties. ✓

✓ A company authorizes a security professional to test only its web server. During testing, the professional notices another vulnerable database server. What should the ethical hacker apply in this situation? *1/1

- Launch vulnerability exploits
- ◉ Review the authorized scope and rules of engagement ✓
- Disable the firewall
- Collect employee passwords

✓ A security professional wants to demonstrate the impact of a vulnerability. Which action best applies ethical hacking practice? *1/1

- ○ Cause maximum possible damage
- ◉ Use the least harmful approved method to demonstrate the risk ✓
- ○ Delete system files
- ○ Publish confidential data

✓ A certified red teamer is hired to test a university's research database. During the engagement, they notice a physically separate HR network is highly vulnerable. The tester decides to deploy a ransomware simulator on it to provide a more comprehensive report. Evaluate this decision from a legal and ethical standpoint. *1/1

- ○ It is legally protected as long as the tester does not monetize or leak the findings.
- ○ It is ethically sound because it improves the client's overall security posture.
- ○ It is valid under standard ethical hacking frameworks provided no data is permanently deleted.
- ◉ It violates explicit authorization, risking severe legal liability and breaching ethical boundaries ✓

✓ A student wants to practice vulnerability scanning on the college network. How should ethical hacking principles be applied? *1/1

- ○ Scan the network without informing anyone
- ◉ Obtain authorization before performing the scan ✓
- ○ Scan only during the night
- ○ Hide the source IP address

✓ An ethical hacker discovers confidential customer information during an authorized penetration test. How should the hacker apply confidentiality principles? *1/1

- ○ Copy the information to a personal device
- ○ Share it with other testers outside the project
- ◉ Protect the information and follow the agreed reporting procedure ✓
- ○ Publish the information as evidence

✓ Months after successfully finishing a penetration test on a regional hospital's network, An independent ethical hacker decides to retain a complete dump of the customer database on a local home server 'just in case'. Critique this post-engagement practice. *1/1

- It is legally required to prove the vulnerabilities existed in case of a future audit dispute.
- It is ethically acceptable as long as the home server is disconnected from the public internet.
- It is a standard industry practice to retain client data for long-term historical benchmarking.
- ◉ It blatantly violates the ethical mandate for secure data destruction and strict confidentiality ✓

✓ A senior security researcher identifies a vulnerability in a public transportation control system without any prior permission and anonymously submits the finding to a public bug tracker. Classify the hacker profile and evaluate the action. *1/1

- White hat behavior; entirely ethical and legal since the ultimate goal was system defense.
- Hacktivism; aimed at political reform by exposing the company's weak security posture.
- Black hat behavior; driven strictly by malicious intent and violation of the CIA triad.
- ◉ Gray hat behavior; well-intentioned but legally perilous due to the strict lack of authorization. ✓

✓ During an authorized assessment, a tester identifies a weak password on an account. Which action appropriately applies ethical hacking principles? *1/1

- ○ Post the password online
- ◉ Use it only as authorized and document the weakness ✓
- ○ Use it to access unrelated accounts
- ○ Give it to other employees

✓ A researcher discovers a vulnerability in a public website without prior authorization. What is the most appropriate ethical action? *1/1

- ○ Exploit it to determine its full impact
- ◉ Avoid unauthorized exploitation and use the site's approved vulnerability-reporting process if available ✓
- ○ Download user information
- ○ Change the vulnerable code

✗ Months after successfully finishing a penetration test on a decentralized cryptocurrency exchange, An internal compliance auditor decides to retain the database of unencrypted credit card transactions on a local home server 'just in case'. Critique this post-engagement practice. *0/1

- (●) It blatantly violates the ethical mandate for secure data destruction and strict confidentiality. ✗
- ( ) It is ethically acceptable as long as the home server is disconnected from the public internet.
- ( ) It is a standard industry practice to retain client data for long-term historical benchmarking.
- ( ) It is legally required to prove the vulnerabilities existed in case of a future audit dispute.

Correct answer

- (●) It is ethically acceptable as long as the home server is disconnected from the public internet.

✓ A security team plans an ethical hacking assessment. Which sequence best applies ethical hacking principles? *1/1

- ( ) Exploit → Obtain permission → Report → Define scope
- (●) Obtain authorization → Define scope → Test → Document → Report ✓
- ( ) Scan → Publish → Obtain permission → Exploit
- ( ) Attack → Collect data → Share → Delete evidence

✓ An independent ethical hacker is offered a contract to audit a federal tax web portal, but they recently was rejected for a full-time role there last week. Judge the decision to accept this auditing contract. *1/1

- [x] Unethical due to a severe conflict of interest that compromises the auditor's objectivity. ✓
- [ ] Legal and ethical, provided they sign a supplementary non-disclosure agreement.
- [ ] Acceptable, as long as they only utilize automated scanning tools to remove bias.
- [ ] Ethical, as their insider knowledge will result in a more thorough security test.

✓ Following an engagement against a cloud storage provider, management strictly asks A network security auditor to change the root cause from 'negligence' to 'advanced threat' in the final official report. Recommend the most ethical response. *1/1

- [ ] Agree to the modification, but charge a premium fee for altering official compliance documents.
- [ ] Alter the report as requested, but leave a hidden cryptographic signature indicating tampering.
- [x] Refuse the request entirely to maintain the integrity, accuracy, and objectivity of the audit. ✓
- [ ] Comply with the request, as the client owns the report and retains final editorial rights.

✓ During an authorized assessment, a tester identifies a critical vulnerability. Which action applies responsible disclosure correctly? *1/1

- ○ Post the vulnerability publicly immediately
- ◉ Report it securely to the authorized organization ✓
- ○ Sell the information
- ○ Ignore the vulnerability

✓ An employee discovers a security flaw in the organization’s internal application. How should proper disclosure be applied? *1/1

- ○ Publish the flaw online
- ◉ Report it through the organization's approved security channel ✓
- ○ Exploit the flaw repeatedly
- ○ Inform unrelated organizations

✓ A penetration tester completes an assessment and has temporary copies of sensitive data collected under authorization. What should be done according to the agreed data-handling policy? *1/1

- ○ Keep the data permanently
- ○ Transfer it to a personal computer
- ◉ Securely retain or dispose of it according to the agreement ✓
- ○ Share it with students

✓ While assessing an online retail platform, A corporate security consultant runs a mass exploitation script without verifying its impact, which inadvertently crashes the primary production database. Assess the primary ethical failure in this scenario. *1/1

- ○ There is no ethical failure, as uncovering deep vulnerabilities inherently requires downtime.
- ○ A violation of Confidentiality, as the system outage likely exposed unencrypted data.
- ◉ Failure to assess operational risk, directly violating the principle of Availability. ✓
- ○ A breach of Non-repudiation, as the tool's execution logs were not preserved.

✓ A tester needs to verify a vulnerability that could potentially crash a production server. Which action best applies ethical principles? *1/1

- ○ Test it immediately on the production server
- ◉ Follow the approved testing procedure and use a safe environment where possible ✓
- ○ Crash the server intentionally
- ○ Ignore all organizational restrictions

✓ After discovering a critical flaw in a biometric authentication API, A freelance vulnerability assessor reports it privately. The vendor ignores the report for 9 months. Frustrated, the researcher decides to upload an automated exploitation script to GitHub. Critique this disclosure strategy. *1/1

- It is ethical as part of the Coordinated Disclosure framework since the grace period expired.
- ◉ It is unethical as it maximizes risk to the public without providing a viable mitigation path. ✓
- It is legally acceptable because the vendor's silence automatically waives their copyright protections.
- It is completely justified under the Full Disclosure model to force the vendor into action.

✓ An ethical hacker finds a vulnerability that could expose thousands of customer records. Which response correctly applies professional ethics? *1/1

- Download all customer records
- ◉ Document the vulnerability while minimizing exposure of customer data ✓
- Publish sample customer records
- Use the data for another project

✓ Upon discovering a severe flaw in a cloud storage provider, A network security auditor contacts the organization and demands $50,000 in Ethereum before providing the vulnerability report. Evaluate this action under ethical hacking laws. *1/1

- It is ethically justified if the organization can easily afford the requested compensation.
- This is an aggressive but legally recognized negotiation tactic within modern bug bounties.
- ◉ This constitutes illegal extortion and is classified as malicious black-hat behavior. ✓
- It is valid under full disclosure guidelines as compensation for the researcher's time.

✓ A company permits testing of its web application but specifically prohibits denial-of-service testing. Which action should the tester take? *1/1

- Perform denial-of-service testing anyway
- ◉ Follow the restriction and avoid denial-of-service testing ✓
- Perform it outside office hours
- Ask another person to perform it

✓ A security tester receives written permission to assess a company network. Which action should the tester perform first to apply ethical hacking principles? *1/1

- Launch vulnerability exploits
- Review the authorized scope and rules of engagement ✓
- Disable the firewall
- Collect employee passwords

✓ Following an engagement against a federal tax web portal, management strictly asks A freelance vulnerability assessor to falsify the date of the test to meet a regulatory deadline in the final official report. Recommend the most ethical response. *1/1

- Alter the report as requested, but leave a hidden cryptographic signature indicating tampering.
- Comply with the request, as the client owns the report and retains final editorial rights.
- Agree to the modification, but charge a premium fee for altering official compliance documents.
- Refuse the request entirely to maintain the integrity, accuracy, and objectivity of the audit. ✓

✓ While assessing a logistics and shipping API, A network security auditor runs a customized payload generator without verifying its impact, which inadvertently locks out all legitimate administrative users. Assess the primary ethical failure in this scenario. *1/1

- ○ A breach of Non-repudiation, as the tool's execution logs were not preserved.
- ◉ Failure to assess operational risk, directly violating the principle of Availability. ✓
- ○ A violation of Confidentiality, as the system outage likely exposed unencrypted data.
- ○ There is no ethical failure, as uncovering deep vulnerabilities inherently requires downtime.

✓ While officially authorized to test a public transportation control system, A junior penetration tester assumes the contract implicitly includes a staging server that closely mirrors production and proceeds to attack it. Judge the legal validity of this assumption. *1/1

- ○ It is legally permissible as long as the actor is a certified and licensed professional.
- ◉ Ethically and legally dangerous; authorization must always be explicit, documented, and unambiguous. ✓
- ○ It is standard practice to ensure no blind spots remain in the client's overall audit.
- ○ It is a valid assumption if both systems share the same internal IP subnet.

✓ A network security auditor is hired to test a social media startup. During the engagement, they notice a deactivated test environment is highly vulnerable. The tester decides to create a new administrative account on it to provide a more comprehensive report. Evaluate this decision from a legal and ethical standpoint. *1/1

- It is valid under standard ethical hacking frameworks provided no data is permanently deleted.
- (●) It violates explicit authorization, risking severe legal liability and breaching ethical boundaries. ✓
- It is ethically sound because it improves the client's overall security posture.
- It is legally protected as long as the tester does not monetize or leak the findings

✓ An ethical hacker is asked to test employee awareness using simulated phishing. What should be established before conducting the exercise? *1/1

- (●) Authorization, scope, and approved procedures ✓
- Employees' personal passwords
- Access to personal email accounts
- Permission from unrelated companies

This form was created inside of Saveetha Institute of Medical and Technical Sciences. - Contact form owner

Does this form look suspicious? Report

Google Forms